Software Design Document

(SDD)

Project Name	HEALTH AI Co-Creation & Innovation Platform
Course	SENG384 - Software Project IV
Group No / Name	WebDevs
Group Members	Eylül Turunç – 202328057 Beril Aşçi – 202228007 Serra Selci – 202228042 Dilan Yardım – 202228052
Submission Date	[23/04/2026]
Version	1.1

Revision History

Date	Version	Change Description	Author
19/04/2026	1.0	Initial version created based on SRS v1.1.	Eylül Turunç, Beril Aşçi, Serra Selci, Dilan Yardım
21/04/2026	1.1	Technical diagrams, database schemas, and interface wireframes are incorporated into this document to support the design specifications.	Eylül Turunç, Beril Aşçi, Serra Selci, Dilan Yardım

Table of Contents

Table of Contents....2
1. Introduction....3
1.1 Purpose....3
1.2 Scope....3
1.3 Reference Documents....3
1.4 Definitions and Abbreviations....3
2. Architectural Design....3
2.1 Architectural Overview....3
2.2 Layers....3
2.3 Deployment Diagram....4
3. Component Design....4
Main Components and Responsibilities....4
3.1 Component List....5
3.2 Component Interaction Diagram....6
4. Database Design....7
4.1 ER Diagram....7
4.2 Table Definitions....7
4.2.1 users....7
4.2.2 posts....8
4.2.3 meeting_requests....8
4.2.4 activity_logs....9
5. API Design....9
5.1 Authentication (Auth)....9
5.2 Post Management (Posts)....9
5.3 Meeting Requests (Meetings)....10
5.4 Admin....10
6. UI Design....10
6.1 Screen List and Navigation....10
6.2 Wireframes / Mockups....11
7. Security Design....13
8. State Diagrams....15
8.1 Post Lifecycle....15
8.2 Meeting Request Lifecycle....16
9. SRS–SDD Traceability Matrix....17

1. Introduction

1.1 Purpose

This SDD defines the technical architecture, component design, and database schema for the HEALTH AI Co-Creation & Innovation Platform. It translates the functional requirements established in the SRS—such as secure matchmaking and NDA-protected meetings—into a system design.

1.2 Scope

The design covers user authentication via institutional emails, a structured post-lifecycle management system, secure messaging, and an administrative audit trail. It excludes patient data storage and financial transactions.

1.3 Reference Documents

HEALTH AI SRS v1.1, April 16, 2026.

Project Brief, SENG384 Software Project IV

1.4 Definitions and Abbreviations

JWT: JSON Web Token for secure session management.

RBAC: Role-Based Access Control.

ORM: Object-Relational Mapping for database operations.

NDA: Non-Disclosure Agreement.

2. Architectural Design

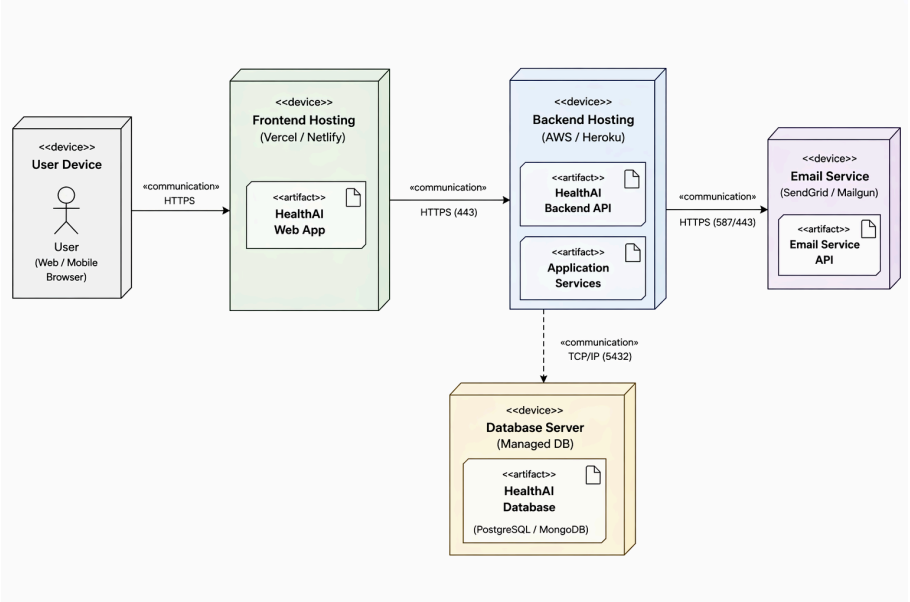
2.1 Architectural Overview

The system follows a **Client-Server** architectural pattern using a **Layered** approach to separate concerns between the UI, business logic, and data storage.

2.2 Layers

Layer	Responsibility	Technology Choice
Presentation	Handles UI rendering and user interactions.	React / Tailwind CSS.
Business Logic	Manages workflows like matchmaking and NDA verification.	Node.js / Express.
Data Access	Mediates between logic and the database.	Prisma or TypeORM.
Database	Persistent storage for users, posts, and logs.	PostgreSQL or MySQL.

2.3 Deployment Diagram



3. Component Design

The system is divided into several main components, each responsible for a specific part of the HealthAI platform. This modular structure improves maintainability, scalability, and separation of concerns.

Main Components and Responsibilities

1. User Interface (Frontend)
This component provides the visual interface for all users, including patients, doctors, and administrators. It handles page rendering, form inputs, navigation, dashboards, messaging screens, appointment views, and profile/settings pages. It communicates with the backend through API requests.

2. Authentication and Authorization Module
This module manages user registration, login, logout, password reset, and session/token handling. It also controls role-based access so that each user type, such as patient, doctor, or admin, can only access the features permitted to them.

3. API Gateway / Backend Application
The backend acts as the central coordinator of the system. It receives requests from the frontend, validates input, applies business logic, communicates with the database, and returns responses. It also connects other services such as AI analysis, notifications, and messaging.

4. Patient Management Module
This component stores and manages patient-related data such as personal details, medical history, uploaded reports, appointments, and AI-generated insights. It ensures patient records are organized and accessible when needed.

5. Doctor Management Module
This module handles doctor profiles, specialization information, availability, assigned patients, and consultation history. It supports doctor-facing dashboards and interactions with patient records.

6. Appointment and Scheduling Module
This component manages appointment booking, cancellation, rescheduling, and time-slot availability. It coordinates between patients and doctors and ensures appointment data is updated consistently.

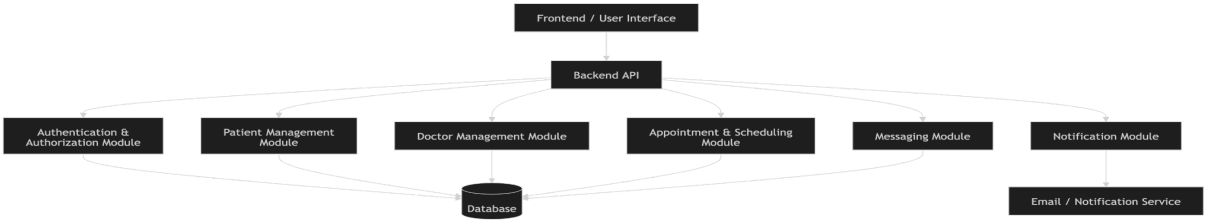
7. AI Analysis Module
This is the intelligent part of the system. It processes health-related inputs such as symptoms, reports, or uploaded medical data and generates predictions, recommendations, or decision-support outputs. This module interacts with the backend and may use trained machine learning models.

8. Messaging / Communication Module
This module enables communication between patients and doctors. It supports secure message exchange, consultation-related chats, and possibly file sharing within the system.

9. Notification Module
This component sends reminders and alerts such as appointment confirmations, password reset emails, important updates, and AI result notifications. It may use email or in-app notification services.

10. Database
The database stores all persistent system data, including users, roles, appointments, messages, reports, AI results, and medical records. It serves as the main storage layer for the platform.

11. External Services
These are third-party or external integrations used by the system, such as email services, cloud storage, or AI model hosting environments. They support the core platform without being directly part of the internal architecture.

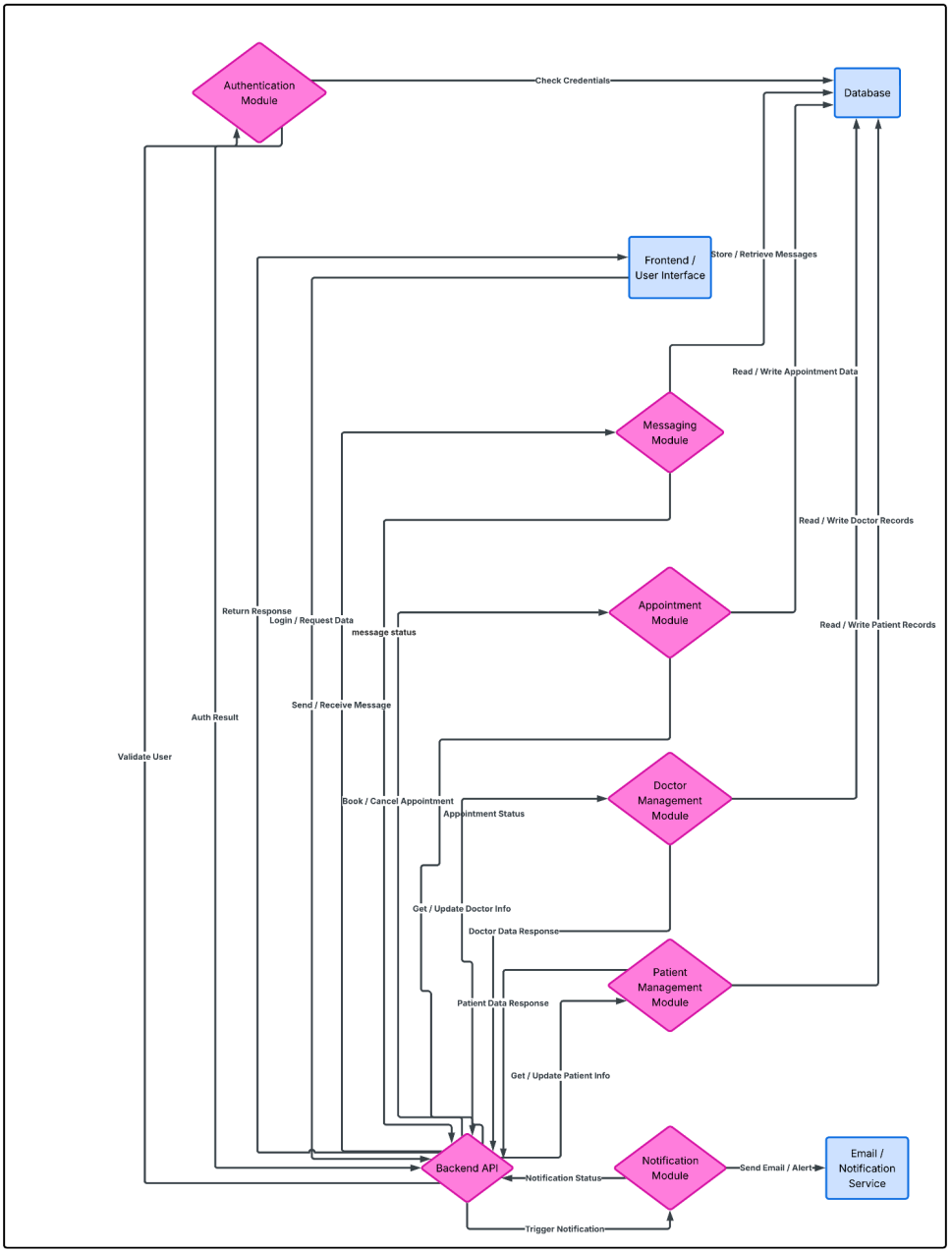


3.1 Component List

Component	Responsibility	Technology / Notes
AuthModule	Restricted .edu registration, email verification, and JWT-based session management.	Passport.js / JWT
ProfileModule	Managing user profile data, institution info, and account status (active/suspended).	React Forms / Express
PostModule	Full lifecycle management of project ideas (Create, Edit, List, Filter, Close).	Express Router / Prisma
MatchModule	Logic for matching Engineers with Healthcare Professionals based on post interests.	Server-side Logic
MeetingModule	Handling time slot proposals, mandating NDA acceptance, and external link sharing.	Socket.io / Crypto API

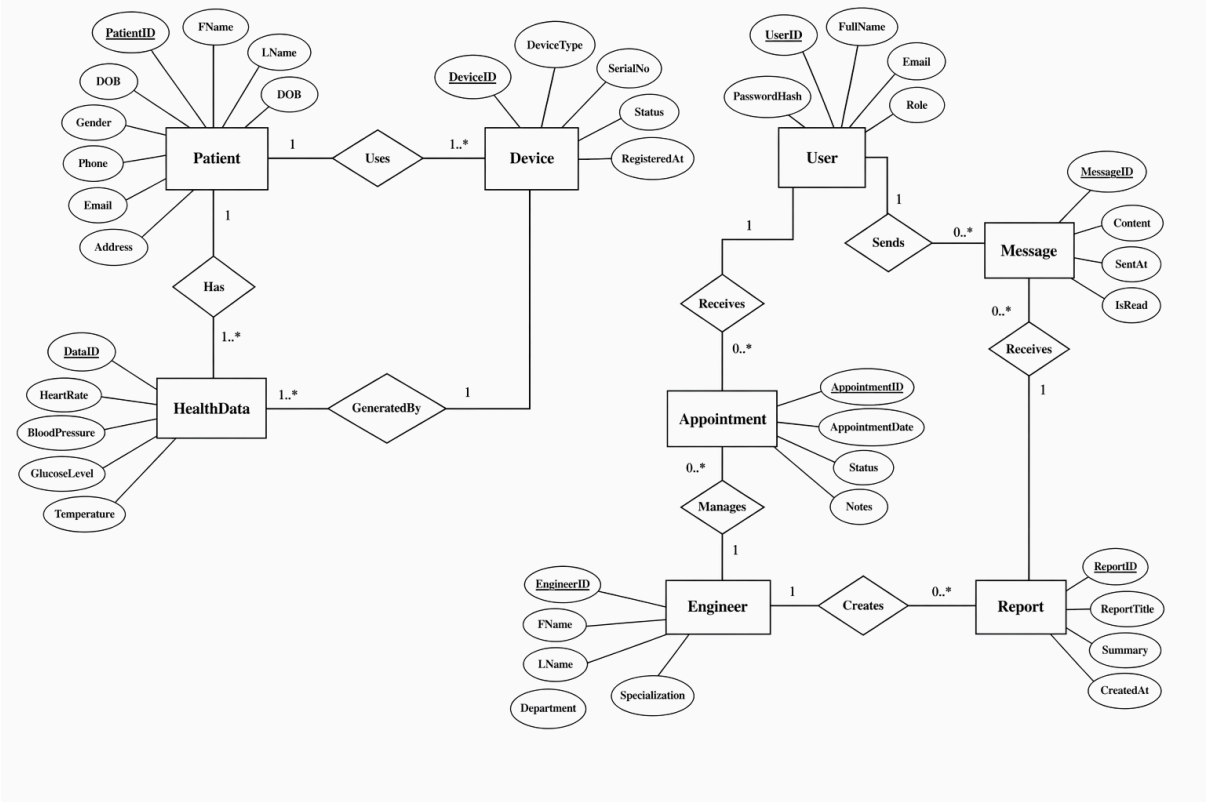
MessagingModule	Secure, text-only direct messaging between matched partners.Text-only communication; file uploads and attachments are disabled to ensure data security.	Socket.io
AdminDashboard	High-level overview, user/post moderation, and system statistics visualization.	React Admin / Chart.js
AuditLogModule	Creating tamper-resistant logs of all key events with 24-month retention.	Winston / PostgreSQL

3.2 Component Interaction Diagram



4. Database Design

4.1 ER Diagram



4.2 Table Definitions

4.2.1 users

Field Name	Data Type	Required	Constraint	Description
id	UUID / INT	Yes	PK	Unique user identifier
email	VARCHAR(255)	Yes	UNIQUE, .edu check	Institutional email
password_hash	VARCHAR(255)	Yes	—	Encrypted password
role	ENUM	Yes	—	engineer / healthcare / admin
institution	VARCHAR	Yes	—	—
bio	TEXT	No	—	User description
status	ENUM	Yes	—	Active / Suspended
created_at	TIMESTAMP	Yes	—	Registration time
last_login_at	TIMESTAMP	No	—	Last login

4.2.2 posts

Field Name	Data Type	Required	Constraint	Description
id	UUID / INT	Yes	PK	Unique post identifier
user_id	UUID / INT	Yes	FK → users	User who created the post
status	ENUM	Yes	—	draft / active / meeting_scheduled / Partner Found/expired
title	VARCHAR(255)	Yes	—	Post title
description	TEXT	Yes	—	Detailed explanation
needed_expertise	VARCHAR(255)	Yes	—	Required expertise
working_domain	VARCHAR(100)	Yes	—	Domain (AI, Medical, etc.)
project_stage	ENUM	Yes	—	Idea / Prototype / Research
collaboration_type	ENUM	Yes	—	Advisor / Co-founder / Partner
commitment_level	ENUM	Yes	—	Part-time / Full-time
confidentiality_level	ENUM	Yes	—	Low / Medium / High
city	VARCHAR(100)	Yes	—	Location city
country	VARCHAR(100)	Yes	—	Location country
expiry_date	DATE	No	—	Expiration date
created_at	TIMESTAMP	Yes	—	Creation time
updated_at	TIMESTAMP	No	—	Last update

4.2.3 meeting_requests

Field Name	Data Type	Required	Constraint	Description
id	UUID / INT	Yes	PK	Meeting request identifier
post_id	UUID / INT	Yes	FK → posts	Related post
requester_id	UUID / INT	Yes	FK → users	Requesting user
receiver_id	UUID / INT	Yes	FK → users	Receiving user
nda_accepted	BOOLEAN	Yes	—	NDA accepted
message	TEXT	Yes	—	Intro message
status	ENUM	Yes	—	Pending / Accepted / Declined / Scheduled / Cancelled

proposed_time_slots	TEXT	No	—	Proposed times
selected_time_slot	TIMESTAMP	No	—	Final time
created_at	TIMESTAMP	Yes	—	Creation timestamp
updated_at	TIMESTAMP	No	—	Last update timestamp
cancelled_at	TIMESTAMP	No	—	Cancellation time

4.2.4 activity_logs

Field Name	Data Type	Required	Constraint	Description
id	UUID / INT	Yes	PK	Log entry identifier
user_id	UUID / INT	Yes	FK → users	User who performed the action
action_type	VARCHAR(100)	Yes	—	login / post_create / meeting_request / ...
target_entity	VARCHAR(100)	Yes	—	Target
result_status	VARCHAR(50)	Yes	—	Success/Fail
ip_address	VARCHAR(50)	No	—	IP
timestamp	TIMESTAMP	Yes	—	Time

5. API Design

5.1 Authentication (Auth)

Method	Endpoint	Description	Auth	SRS Ref.
POST	/api/auth/register	New user registration	Public	FR-01
POST	/api/auth/login	User login	Public	FR-02
POST	/api/auth/verify-email	Email verification	Public	FR-02
POST	/api/auth/logout	End session	Authenticated	—

5.2 Post Management (Posts)

Method	Endpoint	Description	Auth	SRS Ref.
GET	/api/posts	List all posts with independent filters for city and country	Authenticated	FR-23
POST	/api/posts	Create a new post	Authenticated	FR-11
GET	/api/posts/:id	Get post details	Authenticated	—
PUT	/api/posts/:id	Update a post	Owner	FR-15

PATCH	/api/posts/:id/status	Change post status	Owner	FR-16

5.3 Meeting Requests (Meetings)

Method	Endpoint	Description	Auth	SRS Ref.
POST	/api/meetings	Send meeting request	Auth	FR-26
PATCH	/api/meetings/:id	Update	Auth	FR-29
DELETE	/api/meetings/:id	Cancel	Auth	FR-32

5.4 Admin

Method	Endpoint	Description	Auth	SRS Ref.
GET	/api/admin/users	List all users	Admin	FR-37
PATCH	/api/admin/users/:id	Suspend	Admin	FR-39
DELETE	/api/admin/posts/:id	Remove post	Admin	FR-36
GET	/api/admin/logs	View logs	Admin	FR-42

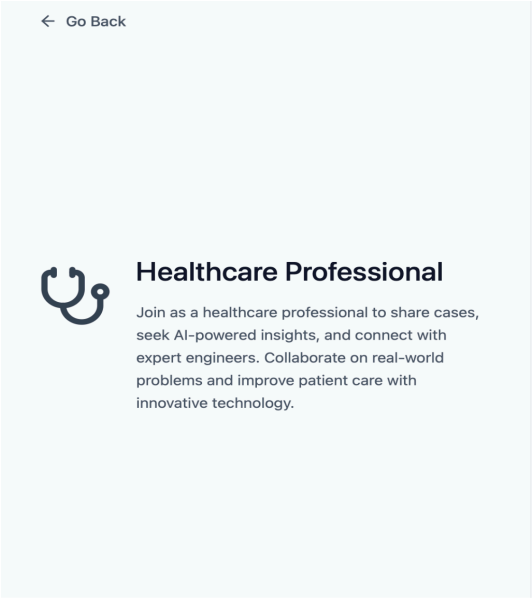
6. UI Design

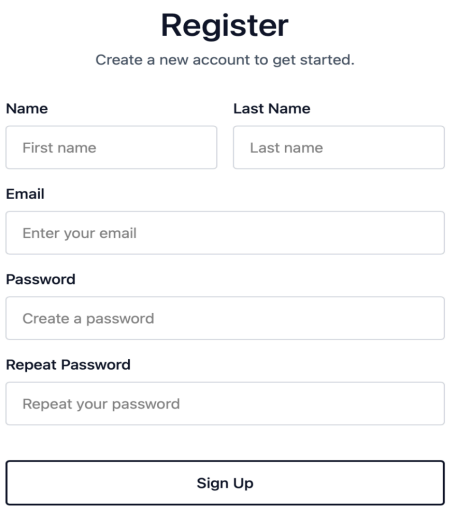
6.1 Screen List and Navigation

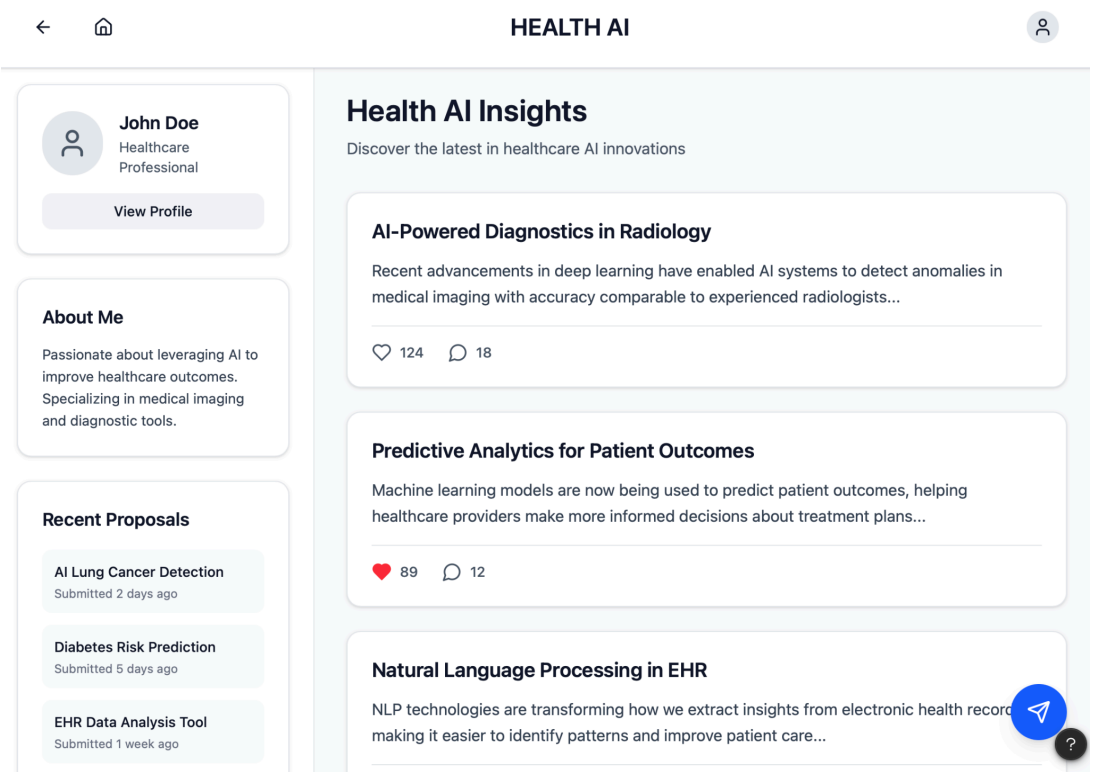
Screen	Description	Access
Registration / Login	Enables users to register with an institutional email and log into the platform securely.	Public
Dashboard	Allows users to browse available posts and apply filters to find relevant collaboration opportunities.	Authenticated
Create Post	Provides a structured interface for users to create and publish new posts with required details.	Authenticated

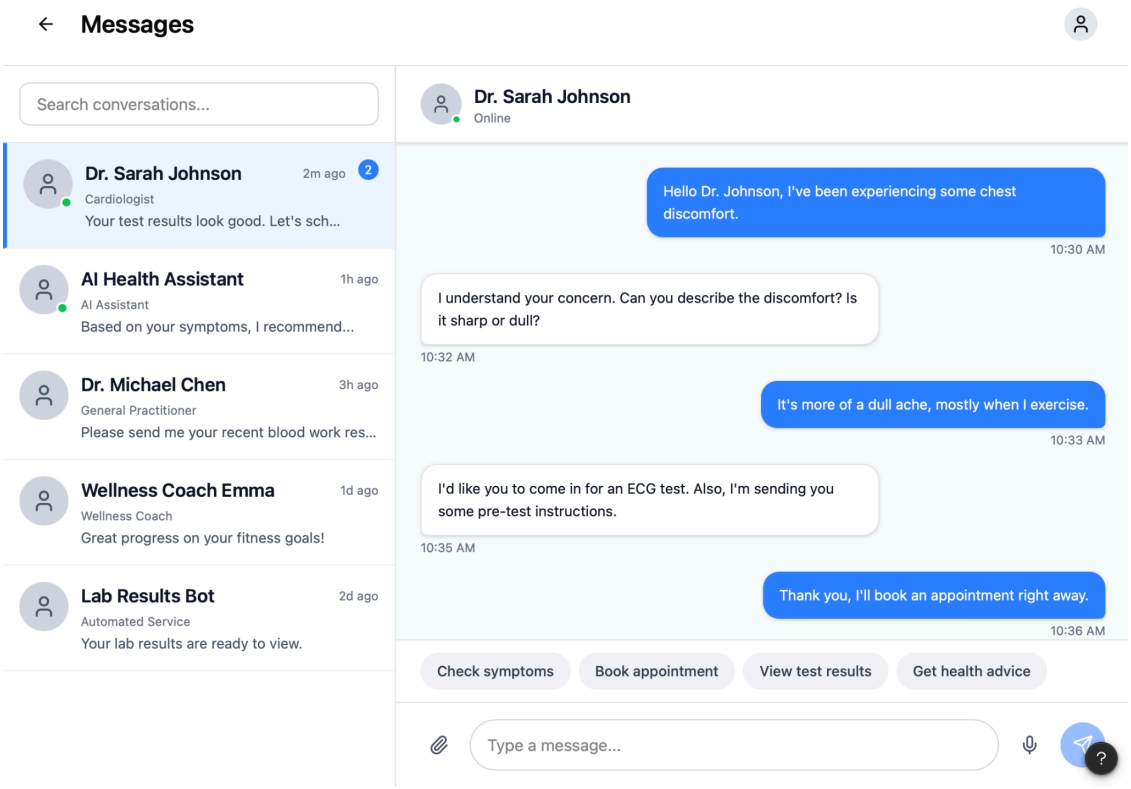
Post Detail	Displays detailed information about a selected post and allows users to interact with it.	Authenticated
Meeting Request	Supports sending, scheduling, and managing meeting requests between users.	Authenticated
Admin Panel	Provides administrative tools to manage users, posts, and monitor platform activities.	Admin
Profile Page	Allows users to view and update their profile information and account details.	Authenticated Users
Messaging / Interest Page	Enables users to send and view interest messages related to posts.	Authenticated Users
Notifications Page	Displays system notifications such as meeting requests and updates.	Authenticated Users
Admin Logs Page	Allows administrators to view, filter, and export system activity logs.	Admin

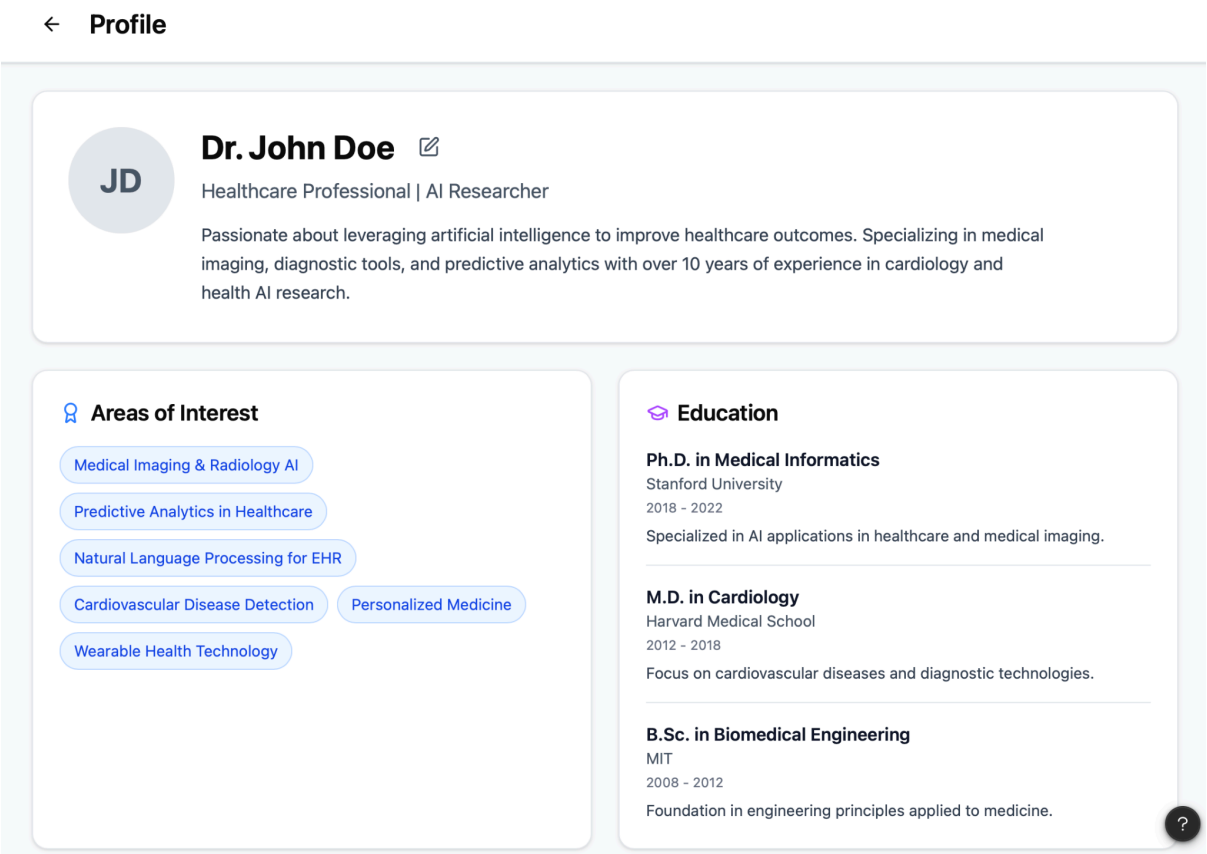
6.2 Wireframes / Mockups






HEALTH AI
John Doe
Healthcare Professional
View Profile
About Me
Passionate about leveraging AI to improve healthcare outcomes. Specializing in medical imaging and diagnostic tools.
Recent Proposals
AI Lung Cancer Detection
Submitted 2 days ago
Diabetes Risk Prediction
Submitted 5 days ago
EHR Data Analysis Tool
Submitted 1 week ago
Health AI Insights
Discover the latest in healthcare AI innovations
AI-Powered Diagnostics in Radiology
Recent advancements in deep learning have enabled AI systems to detect anomalies in medical imaging with accuracy comparable to experienced radiologists...
124
18
Predictive Analytics for Patient Outcomes
Machine learning models are now being used to predict patient outcomes, helping healthcare providers make more informed decisions about treatment plans...
89
12
Natural Language Processing in EHR
NLP technologies are transforming how we extract insights from electronic health record
making it easier to identify patterns and improve patient care...


Messages
Search conversations...
Dr. Sarah Johnson
Cardiologist
2m ago
2
Your test results look good. Let's sch...
AI Health Assistant
AI Assistant
1h ago
Based on your symptoms, I recommend...
Dr. Michael Chen
General Practitioner
3h ago
Please send me your recent blood work res...
Wellness Coach Emma
Wellness Coach
1d ago
Great progress on your fitness goals!
Lab Results Bot
Automated Service
2d ago
Your lab results are ready to view.
Dr. Sarah Johnson
Online
Hello Dr. Johnson, I've been experiencing some chest discomfort.
10:30 AM
I understand your concern. Can you describe the discomfort? Is it sharp or dull?
10:32 AM
It's more of a dull ache, mostly when I exercise.
10:33 AM
I'd like you to come in for an ECG test. Also, I'm sending you some pre-test instructions.
10:35 AM
Thank you, I'll book an appointment right away.
10:36 AM
Check symptoms
Book appointment
View test results
Get health advice
Type a message...



7. Security Design

Explain how the security and GDPR requirements from the SRS will be addressed at the design level.

Security Requirement	Design Decision	SRS Ref.
Authentication	The system uses email-and-password based authentication with institutional email verification before account activation. Only verified users can log in and access authenticated features.	FR-01, FR-02, FR-10
Password Storage	User passwords are never stored in plain text. Passwords are stored using a secure hashing algorithm such as bcrypt with salted hashing.	NFR-05
Authorization (RBAC)	Role-Based Access Control is enforced through backend middleware. Access permissions are checked for Engineer, Healthcare Professional, and Admin roles before protected actions are executed.The system strictly blocks 'Admin' role selection during public registration at the API level. Admin status can only be granted by existing administrators.	FR-05, FR-07

Admin Authorization	The Admin role is not available through public registration. It is assigned only through administrative authorization in the backend.	FR-06
Session Management	Authenticated sessions are protected using signed JWT tokens or secure server-side sessions. Automatic timeout is applied after a defined inactivity period to reduce unauthorized access risk.	FR-09, NFR-06
HTTPS / Secure Transport	All client-server communication is protected through HTTPS. This ensures encryption of credentials, session tokens, and all transmitted platform data.	NFR-04
Email Verification	A verification token is sent to the user's institutional email during registration. The account remains inactive until the token is validated.	FR-02, FR-10
Input Validation	All user inputs are validated both on the client side and server side to prevent invalid data entry, malformed requests, and injection attacks.	FR-11, FR-12, FR-26
Access Protection for Admin Functions	Admin endpoints and admin screens are protected by authorization checks. Only users with the Admin role can access post moderation, user management, and audit log operations.	FR-34, FR-35, FR-37, FR-46
GDPR Compliance	The system follows data minimization principles by storing only the minimum personal data necessary for platform operation. Users are provided with account deletion functionality to support privacy rights.	NFR-07, NFR-08
No Patient Data Storage	The design explicitly excludes patient records, medical files, and sensitive clinical documents from storage. File upload functionality is not provided for posts.	FR-18, FR-47
Audit Logging	Security-relevant actions such as login, failed login, post changes, meeting request changes, and admin operations are recorded in tamper-resistant activity logs.	FR-42, FR-43, FR-44
Log Protection	Logs are accessible only to Admin users. Log records are designed to be append-only at the application level	FR-44, FR-45, FR-46

	and retained for the defined retention period.	
Data Exposure Control	Meeting details are limited to platform scheduling information. Meetings are conducted externally, and no recordings are stored by the system.	FR-33
Rate Limiting and Abuse Prevention	Login, registration, and sensitive endpoints should use rate limiting to reduce brute-force and spam attempts. Additional anti-bot controls may be applied to public endpoints if necessary.	NFR-04, NFR-06
Error Handling	Security-sensitive error messages are generalized to avoid exposing internal implementation details, user existence information, or database structure.	NFR-04
Backup and Recovery	Database backups should be stored securely and access-controlled. Recovery procedures must preserve core platform records and audit integrity.	FR-42, FR-45
Authentication	The system uses email-and-password based authentication with institutional email verification before account activation. Only verified users can log in and access authenticated features.	FR-01, FR-02, FR-10

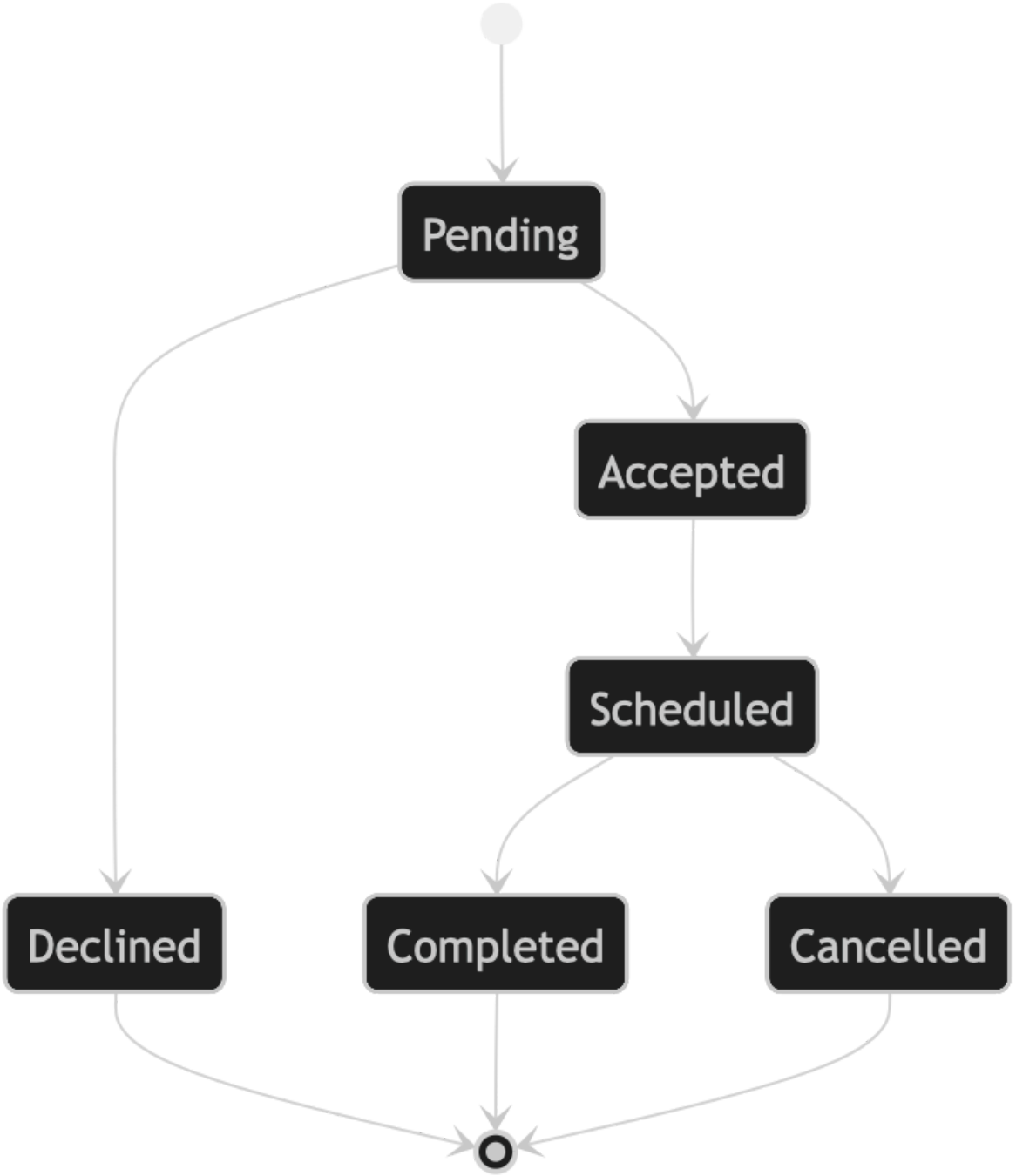
8. State Diagrams

8.1 Post Lifecycle

Draft → Active	User clicks “Publish”
Draft → Expired	Expiry date reached before publishing
Active → Active	User edits post
Active → Meeting Scheduled	Both users accept NDA and a specific time slot is confirmed.
Active → Partner Found	User marks post as “Partner Found”
Active → Expired	Expiry date is reached
Active → Expired	Auto-close condition is triggered
Meeting Scheduled → Partner Found	User confirms successful collaboration after meeting
Meeting Scheduled → Active	Meeting request is cancelled or collaboration does not proceed
Meeting Scheduled → Expired	Expiry condition is reached before final closure

Partner Found	Final state
Expired	Final state

8.2 Meeting Request Lifecycle



9. SRS–SDD Traceability Matrix

SRS Ref.	Requirement Summary	SDD Component	SDD Section
FR-01	Registration restricted to institutional .edu emails	AuthModule	Sections 3.1, 4.2.1, 5.1, 7
FR-02	Email verification mechanism	AuthModule, NotificationModule	Sections 3.1, 5.1, 7
FR-03	Role selection during registration	AuthModule	Sections 4.2.1, 5.1
FR-04	Reject personal email providers	AuthModule	Sections 5.1, 7
FR-05	Enforce RBAC for authenticated users	AuthModule, AdminModule	Sections 2.2, 3.1, 5.4, 7
FR-06	Admin role assigned only through administrative authorization	AuthModule, AdminModule	Sections 4.2.1, 5.4, 7
FR-07	Restrict administrative functions to Admin role	AdminModule	Sections 3.1, 5.4, 7
FR-08	Login required before post and meeting actions	AuthModule	Sections 5.1, 6.1, 7
FR-09	Authenticated session management	AuthModule	Sections 5.1, 7
FR-10	Prevent login before email verification	AuthModule	Sections 5.1, 7
FR-11	Create structured posts with required fields	PostModule	Sections 3.1, 4.2.2, 5.2, 6.1
FR-12	Role-based post form fields	PostModule	Sections 3.1, 5.2, 6.1
FR-13	Post lifecycle states	PostModule	Sections 4.2.2, 5.2, 8.1
FR-14	Save post as Draft	PostModule	Sections 4.2.2, 5.2, 8.1
FR-15	Edit active or draft posts	PostModule	Sections 5.2, 6.1
FR-16	Mark post as Partner Found and close it	PostModule	Sections 5.2, 8.1
FR-17	Automatically transition posts to Expired	PostModule	Sections 4.2.2, 8.1
FR-18	Prohibit file uploads, patient data, and repository functions	PostModule, Security Design	Sections 5.2, 7
FR-19	Require country and city for posts	PostModule	Sections 4.2.2, 5.2
FR-20	Archive posts or allow expiry	PostModule	Sections 5.2, 8.1
FR-21	Specify collaboration type	PostModule	Sections 4.2.2, 5.2
FR-22	Specify level of commitment	PostModule	Sections 4.2.2, 5.2
FR-23	Filter posts by domain, expertise, city, country, stage, and status	MatchingModule, PostModule	Sections 3.1, 5.2, 6.1
FR-24	Highlight city-based matches	MatchingModule	Sections 3.1, 5.2
FR-25	Provide match explanation	MatchingModule	Sections 3.1, 5.2, 6.1
FR-26	Express interest through a short	MeetingModule,	Sections 3.1, 4.2.3, 5.3,

	introductory message	NotificationModule	6.1
FR-27	Submit formal meeting request after acknowledgment and time proposal	MeetingModule	Sections 4.2.3, 5.3, 8.2
FR-28	NDA acceptance required before request submission	MeetingModule	Sections 4.2.3, 5.3, 7
FR-29	Accept or decline meeting requests	MeetingModule	Sections 5.3, 8.2
FR-30	Propose multiple meeting time slots	MeetingModule	Sections 4.2.3, 5.3, 6.1
FR-31	Confirm time slot and update post status to Meeting Scheduled	MeetingModule, PostModule	Sections 5.3, 8.1, 8.2
FR-32	Cancel meeting request before finalization	MeetingModule	Sections 5.3, 8.2
FR-33	Inform users that meetings occur externally and no recordings are stored	MeetingModule, UI Design	Sections 5.3, 6.1, 7
FR-34	Provide RBAC-protected Admin Dashboard	AdminModule	Sections 3.1, 5.4, 6.1, 7
FR-35	Admin can view and filter all posts	AdminModule	Sections 5.4, 6.1
FR-36	Admin can remove inappropriate posts	AdminModule	Sections 5.4, 6.1
FR-37	Admin can view all users and profile completeness	AdminModule	Sections 5.4, 6.1
FR-38	Admin can filter users by role	AdminModule	Sections 5.4, 6.1
FR-39	Admin can suspend or deactivate accounts	AdminModule	Sections 5.4, 7
FR-40	Admin can view platform statistics and post lifecycle history	AdminModule, AuditModule	Sections 5.4, 6.1
FR-41	Admin can view user activity metrics	AdminModule, AuditModule	Sections 5.4, 6.1
FR-42	Comprehensive logging of key events	AuditModule	Sections 3.1, 4.2.4, 5.4, 7
FR-43	Log entry data fields	AuditModule	Sections 4.2.4, 7
FR-44	Tamper-resistant and Admin-only logs	AuditModule, Security Design	Sections 5.4, 7
FR-45	Retain logs for 24 months	AuditModule	Sections 4.2.4, 7
FR-46	Admin log dashboard with filtering and CSV export	AuditModule, AdminModule	Sections 5.4, 6.1
FR-47	Exclude patient data and	AuditModule, Security	Sections 4.2.4, 7

	sensitive technical details from logs	Design	
NFR-01	Search results under 1.5 seconds	MatchingModule, Database Design	Sections 2, 3.1, 4, 5.2
NFR-02	Page load under 3 seconds	Presentation Layer, Frontend Design	Sections 2.2, 6
NFR-03	Support 1000 concurrent users	Deployment Design, Backend Architecture	Sections 2.1, 2.3
NFR-04	HTTPS mandatory	Security Design	Section 7
NFR-05	Secure password hashing	AuthModule, Security Design	Sections 4.2.1, 7
NFR-06	Automatic session timeout	AuthModule, Security Design	Section 7
NFR-07	Data minimization	Security Design, Database Design	Sections 4, 7
NFR-08	Right to delete account and personal data	AdminModule, Security Design	Sections 5.4, 7
NFR-09	Workflow understandable within 20 seconds	UI Design	Section 6
NFR-10	Announcement creation in 3 minutes / 3 steps	UI Design, PostModule	Sections 5.2, 6
NFR-11	WCAG 2.1 compliance	UI Design	Sections 6, 7
NFR-12	Mobile responsiveness	UI Design	Section 6